UNIVERSIDAD DE LAS FUERZAS ARMADAS ESPE



DEPARTAMENTO DE CIENCIAS DE LA COMPUTACIÓN

DESARROLLO DE SOFTWARE SEGURO

ING. ANGEL CUDCO

NRC:36902

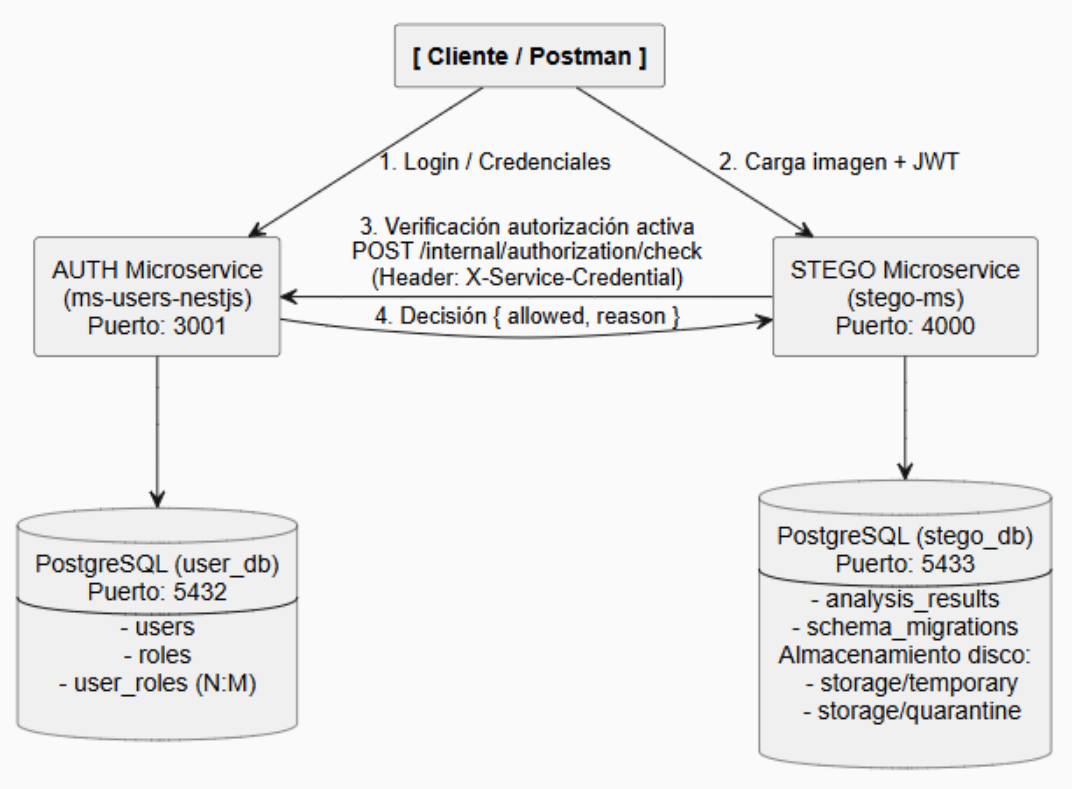
PROYECTO INTEGRADOR PRIMER PARCIAL

INTEGRANTES

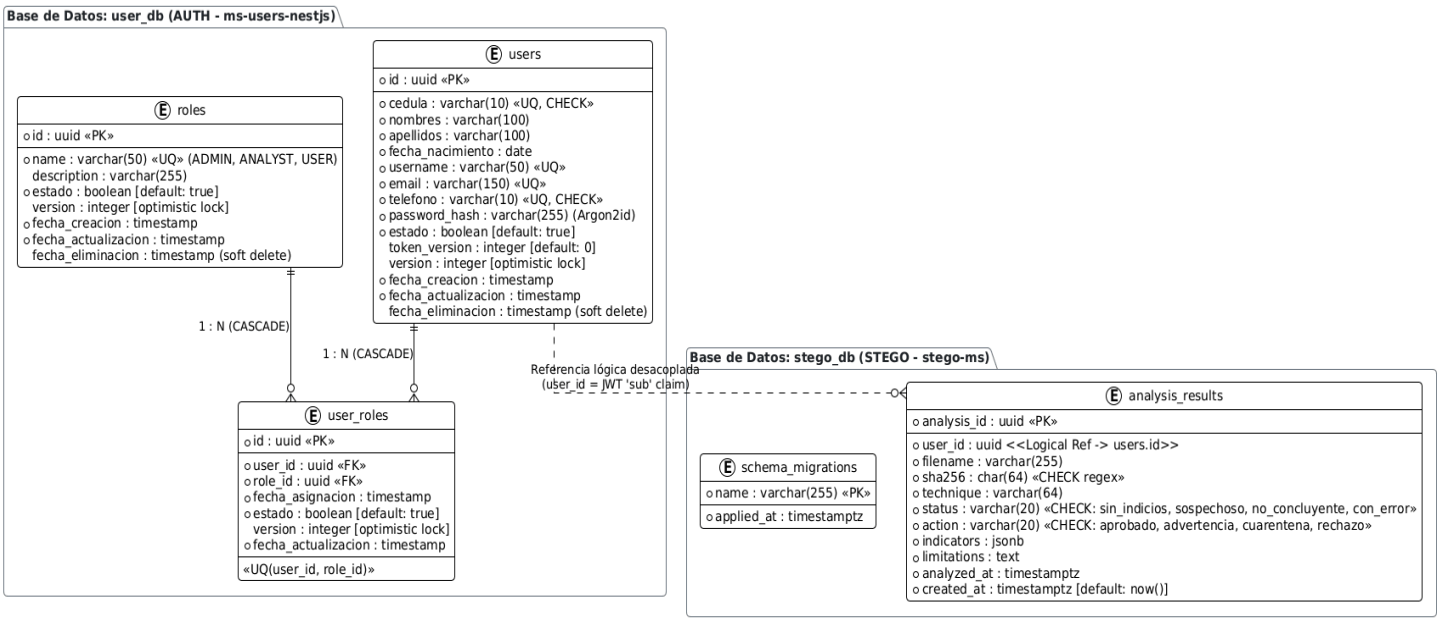
Cap. Davila Anabel
Cordero Martin
Llumiquinga Ariel

Quito, 5 de noviembre del 2026

1. **Código Fuente:** https://github.com/MartinCordero7/Proyecto_P1_DSS
2. **Diagrama de arquitectura**



3. **Diagrama entidad relación**



4. Justificación técnica del método de detección esteganográfica (STEGO)

El microservicio STEGO implementa la técnica `lsb_statistical_analysis`: un análisis estadístico del bit menos significativo (LSB) sobre imágenes PNG y BMP. Un resultado sospechoso es un indicio, no una prueba definitiva de esteganografía. El procesamiento es real: se leen los píxeles del archivo y se calculan los indicadores; no hay resultados simulados.

Fundamentos y técnicas de ocultamiento

La esteganografía oculta la existencia de un mensaje dentro de un portador de apariencia inocua; la criptografía, en cambio, protege el contenido pero no oculta que existe. En imágenes, las técnicas se agrupan en: dominio espacial (modifican directamente los píxeles, por ejemplo LSB), dominio transformado (coeficientes DCT en JPEG), basadas en paleta, basadas en el formato (datos tras el fin del archivo o en bloques auxiliares) y adaptativas (eligen los píxeles según la textura). Por el alcance del proyecto, STEGO acepta PNG y BMP, formatos sin pérdida donde LSB es la técnica más común y verificable.

Método LSB y rastro estadístico

Cada canal de color usa 8 bits (valores de 0 a 255). El LSB aporta solo ±1 al valor, por lo que reemplazarlo con bits del mensaje es imperceptible; la capacidad es de 1 bit por canal y píxel. Al reemplazarlo, los valores 2k y 2k+1 (un «par de valores») se convierten entre sí. Si el mensaje es aleatorio o está cifrado, tras una incrustación completa las frecuencias de ambos valores tienden a igualarse, mientras que en una imagen natural suelen diferir. Ese es el rastro que se detecta.

Indicadores calculados

- **Chi-cuadrado de pares de valores (Westfeld y Pfitzmann), indicador principal.** Para cada par se compara la frecuencia observada de 2k con la esperada si el par estuviera igualado. Un valor p cercano a 1 es consistente con incrustación LSB; cercano a 0 indica una imagen sin ese rastro. Se evalúa de forma progresiva sobre el primer 2 %, 4 %, 6 %, 8 %, 10 %, 15 %, 20 %, 30 %… hasta el 100 % de las muestras y se conserva el máximo, para detectar cargas parciales que la imagen completa diluiría. Para limitar los falsos positivos no se evalúa ninguna ventana con menos de 5 000 muestras, se exigen al menos 10 000 muestras por canal y 20 grados de libertad, y se excluyen los pares con frecuencia esperada menor que 5.
- **Proporción de LSB en 1 (apoyo).** Una carga aleatoria o cifrada la acerca a 0,5.
- **Correlación serial del plano LSB (apoyo).** Una carga aleatoria destruye la estructura entre píxeles vecinos y lleva la correlación hacia 0. Los dos indicadores de apoyo se registran en el resultado, pero no intervienen en la decisión hasta contar con más muestras.

El puntaje de anomalía (`anomaly_score`) es el mayor valor p obtenido entre ventanas y canales (R, G y B).

Formatos admitidos

Se analizan PNG de 8 bits por canal (gris o RGB, con o sin alfa; el canal alfa se descarta) y BMP sin comprimir de 24 y 32 bits. Las imágenes válidas que no pueden analizarse de forma

fiable con este método (PNG con paleta o de 16 bits, BMP de 1, 4, 8 o 16 bits y BMP comprimidos) se clasifican como no_concluyente en lugar de emitir un veredicto engañoso. JPEG no está soportado: su dominio de transformada requiere otras técnicas.

Limitaciones

- **Indicio, no prueba.** Un sin_indicios no garantiza la ausencia de datos ocultos y un sospechoso puede ser un falso positivo. Cada respuesta incluye el campo limitations.
- **Cargas pequeñas.** Las cargas de menos del 10 % de la capacidad se detectaron solo en parte de las muestras medidas.
- **Cargas de baja entropía.** Un texto plano no se detectó: sus bits no son aleatorios y no igualan los pares de valores. El método es eficaz con cargas cifradas o comprimidas.
- **Otras técnicas.** LSB matching (±1) y las técnicas adaptativas (HUGO, WOW, S-UNIWARD) no generan la igualación de pares, por lo que el chi-cuadrado no las detecta; la incrustación en posiciones pseudoaleatorias diluye el efecto.
- **Imágenes poco informativas.** Las imágenes planas o de pocos colores pueden resultar no_concluyente; las que tienen mucho ruido pueden producir falsos positivos.
- **Fuera de los píxeles.** No se analizan los datos ocultos tras el fin del archivo, en bloques auxiliares del PNG o en el relleno del BMP, ni el canal alfa.
- **Orden de lectura.** El análisis recorre los píxeles de arriba hacia abajo y de izquierda a derecha; una herramienta que escriba en otro orden podría atenuar la detección de una carga parcial.
- **Adversario consciente.** Quien conozca el detector puede adaptar la incrustación para evadirlo.

5. Clasificación, umbrales y registro del análisis

Con el puntaje de anomalía, STEGO clasifica cada imagen en uno de cuatro estados y aplica una política (acción). Los umbrales son configurables mediante las variables de entorno STEGO_SUSPICIOUS_THRESHOLD y STEGO_CLEAN_THRESHOLD.

Estado	Condición	Acción
sin_indicios	Puntaje menor que 0,40, con datos suficientes	aprobado: se elimina el archivo temporal
sospechoso	Puntaje mayor o igual que 0,75, con datos suficientes	cuarentena: el archivo se aísla en storage/quarantine
no_concluyente	Puntaje entre 0,40 y 0,75; o imagen pequeña, de pocos colores o con formato no analizable	advertencia: se informa y se elimina el archivo temporal
con_error	La imagen no pudo decodificarse	rechazo: se elimina el archivo temporal

Calibración con imágenes reales

Se midió el detector con 24 fotografías reales (fondos de pantalla redimensionados a 640 px de ancho y guardados sin pérdida) y con 3 fotografías propias tomadas con un iPhone. A cada una se le incrustó, con un incrustador de referencia, una carga aleatoria (equivalente a un mensaje cifrado) a distintas proporciones de la capacidad de la imagen.

- **Imágenes originales:** puntaje máximo de 0,0143 en las 24 fotografías y de 0,015 en las 3 propias. Ninguna superó el umbral de 0,40 (0 falsos positivos).
- **Carga aleatoria en las 24 fotografías:** detectada (puntaje ≥ 0,75) en 22 con el 25 % de la capacidad, en 9 con el 10 %, en 6 con el 3 % o el 5 %, y en 1 con el 1 %.
- **Carga aleatoria en las 3 fotografías propias:** detectada en las 3, con puntaje 1,0, con cargas del 10 %, 50 % y 100 %.
- **Carga de texto plano al 100 %:** no detectada en las 3 fotografías propias (puntajes 0,38, 0,71 y 0,19).
- **Conclusión:** los puntajes son bimodales (cercanos a 0 sin carga y a 1 con carga fuerte), por lo que los umbrales 0,40 y 0,75 no son sensibles a su valor exacto y se mantuvieron.

Estos resultados describen las muestras medidas y no constituyen una garantía para imágenes de otras fuentes.

Registro del análisis y persistencia

Cada análisis se guarda en la base de datos PostgreSQL propia de STEGO (tabla `analysis_results`, ver el diagrama entidad relación) con: identificador del análisis, usuario solicitante (claim `sub` del JWT), nombre del archivo, hash SHA-256, técnica ejecutada, estado, indicadores calculados, acción (política aplicada), limitaciones y fecha. La base de datos rechaza estados, acciones o hashes inválidos mediante restricciones `CHECK` y todas las consultas están parametrizadas.

Si el resultado no puede guardarse, el servicio responde HTTP 503 y no devuelve un análisis que no pueda auditarse; el archivo sospechoso se aísla de todos modos. Un resultado solo puede consultarlo su propietario: el de otro usuario se rechaza con HTTP 403 sin revelar ningún dato.

6. Muestras de imágenes y resultados reales

Las muestras se generan de forma reproducible con `npm run samples:generate` a partir de 3 fotografías propias tomadas con un iPhone. De cada fotografía se producen 7 archivos: la imagen original (PNG y BMP, sin datos ocultos conocidos) y copias con una carga real incrustada mediante LSB. El generador vuelve a leer cada copia desde el disco y extrae la carga oculta; si no coincide, aborta, lo que demuestra que las muestras contienen datos ocultos reales. Los archivos no conservan metadatos EXIF (no incluyen ubicación ni datos del dispositivo).

Resultados reales del motor (`npm run samples:analyze`), con el estado y el puntaje de anomalía de cada muestra:

Muestra	Dato oculto	IMG_5479	IMG_9974	IMG_E7306
original (PNG y BMP)	Ninguno	sin_indicios (0,0151)	sin_indicios (0,0000)	sin_indicios (0,0000)
lsb_aleatorio_100 (PNG)	Aleatorio, 100 %	sospechoso (1,0000)	sospechoso (1,0000)	sospechoso (1,0000)
lsb_aleatorio_50 (PNG y BMP)	Aleatorio, 50 %	sospechoso (1,0000)	sospechoso (1,0000)	sospechoso (1,0000)
lsb_aleatorio_10 (PNG)	Aleatorio, 10 %	sospechoso (1,0000)	sospechoso (1,0000)	sospechoso (1,0000)
lsb_texto_100 (PNG)	Texto plano, 100 %	sin_indicios (0,3824)	no_concluyente (0,7056)	sin_indicios (0,1868)

Las 6 imágenes originales se aprueban y las 12 muestras con carga aleatoria se marcan como sospechosas (cuarentena). Las 3 muestras de texto plano no se detectan, lo que ilustra la limitación de las cargas de baja entropía. Los archivos están en `stego-ms/samples/generated/` y el informe completo en `stego-ms/samples/resultados.md`.



Figura 1. Fotografía IMG_9974: original (izquierda) y con carga LSB aleatoria al 50 % (derecha). A simple vista son indistinguibles.

7. Pruebas reproducibles de STEGO

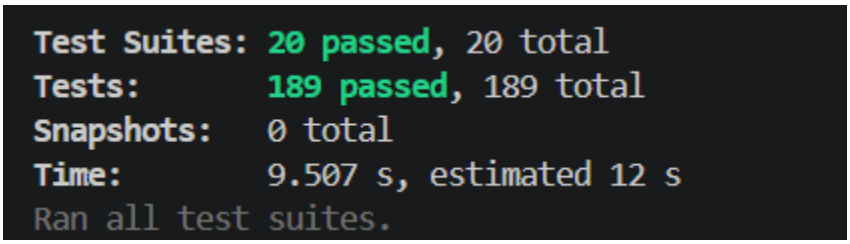
Las pruebas se ejecutan con `npm test` en la carpeta `stego-ms` (Jest y Supertest) y son reproducibles. Resultado: 189 pruebas, 189 superadas, en 20 archivos. Además, 9 pruebas del repositorio se ejecutan contra el PostgreSQL real con `npm run test:db`. Como AUTH es un microservicio independiente, en las pruebas de STEGO su decisión de autorización se simula; la demostración con AUTH real se realiza en la sustentación.

Tipo	Pruebas	Qué verifican
Unitarias	153	Lector de píxeles PNG y BMP, analizador LSB, distribución chi-cuadrado, clasificador, motor, repositorio con consultas parametrizadas, validación de imágenes, hash SHA-256, almacenamiento y cuarentena, cliente de AUTH, auditoría y generación de muestras
Integración	23	API completa con el motor real: análisis, guardado, cuarentena, propiedad del resultado, fallo seguro al no poder guardar y respuestas 401, 403, 413, 415, 422 y 503
Seguridad	13	JWT manipulado, vencido, sin sub y con alg none; suplantación de extensión; imágenes corruptas; revocación inmediata de roles y fallo seguro con AUTH caído
Base de datos real	9	Guardado y lectura, JSON anidado, nombres de archivo hostiles, clave duplicada y restricciones CHECK (npm run test:db)

Correspondencia con los escenarios mínimos de prueba (parte de STEGO)

Escenario	Resultado esperado	Evidencia
T03: JWT ausente, manipulado o vencido	HTTP 401	jwtSecurity.test.js, steganography.api.test.js
T04: usuario sin privilegios	HTTP 403	zeroTrustAuth.test.js
T07: rol retirado con el mismo JWT vigente	Operación denegada	zeroTrustAuth.test.js (dos consultas a AUTH; la segunda deniega)
T08: AUTH inaccesible	HTTP 503, sin procesar el archivo	zeroTrustAuth.test.js, authClient.service.test.js
T09: imagen original y con carga LSB	Métricas, clasificación y limitaciones	lsbEngine.test.js, samples.test.js y la sección de muestras
T10: archivo inválido, corrupto o demasiado	HTTP 415, 422 o 413	imageSecurity.test.js, steganography.api.test.js

grande		
T11: análisis de otro usuario	HTTP 403	analysisFlow.test.js
T12: bitácoras sin secretos	Trazabilidad sin JWT completos	audit.test.js, analysisFlow.test.js

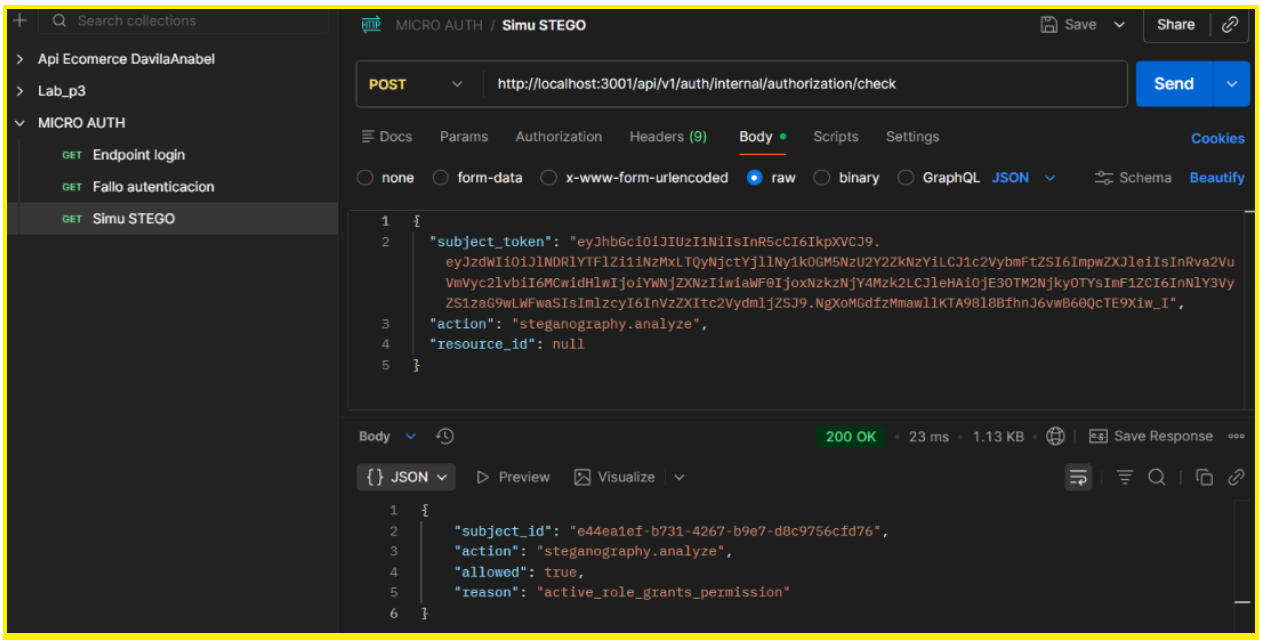


8. OpenAPI y colección de solicitudes REST de STEGO

La especificación OpenAPI 3.0 de STEGO está en el repositorio (stego-ms/docs/openapi.yaml). Documenta el registro completo del análisis, los indicadores calculados y todos los códigos de respuesta (401, 403, 413, 415, 422, 503, entre otros). Las rutas de STEGO son:

- POST /api/steganography/analyze: recibe la imagen en multipart/form-data. Requiere JWT y autorización vigente en AUTH (ADMIN o ANALYST).
- GET /api/steganography/results/:id: consulta un resultado. Requiere JWT, autorización en AUTH y propiedad del recurso.
- GET /health: comprobación de estado, de acceso público.

La colección de solicitudes REST para Postman (stego-ms/docs/postman/stego-ms.postman_collection.json) contiene 10 solicitudes: inicio de sesión en AUTH, análisis de una muestra con carga LSB y de una original, consulta del resultado propio, y casos negativos (sin token, token manipulado, archivo no permitido, resultado inexistente y resultado de otro usuario).



9. Registros de auditoría de STEGO

Cada petición y cada análisis dejan una línea JSON con la etiqueta [AUDIT]. Solo se escriben campos de una lista permitida (usuario, identificador de análisis, hash, estado, acción, motivo, método, ruta, código HTTP y duración): los JWT, las cabeceras, las contraseñas y el contenido de los archivos no pueden registrarse aunque se pasen por error, y los saltos de línea quedan neutralizados. Ejemplo real, generado al analizar una muestra con carga LSB, intentar consultar su resultado con otro usuario y llamar al servicio sin token:

[AUDIT] {"ts":"2026-11-04T23:47:34.736Z","event":"analysis.completed","user_id":"a1b2c3d4-e5f6-4890-abcd-ef1234567890","analysis_id":"3f183700-9ee0-44ce-a81f-ec4bcabfff97","sha256":"bc9c24ea03a0254c9764155975d5eb7e4343b2e01e8a60d9c106d5d273a43cf3","status":"sospechoso","action":"cuarentena"}

[AUDIT] {"ts":"2026-11-04T23:47:34.738Z","event":"http.request","user_id":"a1b2c3d4-e5f6-4890-abcd-ef1234567890","method":"POST","path":"/api/steganography/analyze","http_status":200,"duration_ms":77}

[AUDIT] {"ts":"2026-11-04T23:47:34.747Z","event":"result.denied","user_id":"9f8e7d6c-5b4a-4321-8fed-cba987654321","analysis_id":"3f183700-9ee0-44ce-a81f-ec4bcabfff97","reason":"not_owner"}

[AUDIT] {"ts":"2026-11-04T23:47:34.748Z","event":"http.request","user_id":"9f8e7d6c-5b4a-4321-8fed-cba987654321","method":"GET","path":"/api/steganography/results/3f183700-9ee0-44ce-a81f-ec4bcabfff97","http_status":403,"duration_ms":2}

[AUDIT] {"ts":"2026-11-04T23:47:34.754Z","event":"http.request","method":"POST","path":"/api/steganography/analyze","http_status":401,"duration_ms":0}

Ninguna línea contiene el JWT ni datos del archivo; una prueba automática lo verifica (analysisFlow.test.js). La última línea corresponde a una petición sin token, rechazada con HTTP 401.

10. Guía de ejecución de STEGO

Requisitos: Node.js 22, Docker Desktop abierto y el repositorio clonado (`git clone https://github.com/MartinCordero7/Proyecto_P1_DSS`). Desde la carpeta `stego-ms`:

1. Instalar las dependencias: `npm install`
2. Crear la configuración: copiar `.env.example` a `.env` y definir `STEGO_DB_PASSWORD` (mínimo 12 caracteres, sin valor por defecto) y `AUTH_SERVICE_CREDENTIAL`. El archivo `.env` no se sube al repositorio.
3. Levantar la base de datos de STEGO: `docker compose up -d stego-db` (puerto 5433) y esperar el estado `healthy` con `docker compose ps`.
4. Crear la tabla de resultados: `npm run db:migrate`
5. Iniciar el servicio: `npm start` (puerto 4000). Debe mostrar «Database connection OK» y `GET /health` responde 200.
6. Ejecutar las pruebas: `npm test` y, con la base levantada, `npm run test:db`.
7. Regenerar y analizar las muestras: `npm run samples:generate` y `npm run samples:analyze`.

Para integrar STEGO con AUTH, `AUTH_BASE_URL` debe apuntar a `http://localhost:3001/api/v1/auth` y los valores de `JWT_ISSUER` y `JWT_AUDIENCE` deben coincidir con los configurados en AUTH.

11. Matriz de activos, amenazas, vulnerabilidades, riesgos y controles

ID	Activo	Amenaza	Vulnerabilidad	Prob	Imp	Nivel de riesgo	Control Implementado / Esperado (Evidencia en el Sistema)
01	Credenciales e identidades (AUTH)	Suplantación de identidad, ataques de fuerza bruta y divulgación de contraseñas.	Uso de funciones hash vulnerables o ausencia de límites en el inicio de sesión.	A	A	Alto	Hashing robusto con Argon2id, validación estricta de DTOs y limitador de tasa `@Throttle(5 req / 60s)` en `POST /api/v1/auth/login`. *(Evidencia: ms-users-nestjs/src/auth/)*
02	Asignaciones N:M y roles (AUTH)	Elevación de privilegios horizontal o vertical; inconsistencia de roles asignados.	Falta de integridad referencial o ausencia de unicidad en la tabla asociativa.	M	A	Alto	Claves foráneas hacia `users` y `roles` con restricción `@Unique(['user', 'role'])` en la entidad `user_roles`. Endpoints CRUD protegidos con `RolesGuard` exclusivo para `ADMIN`. *(Evidencia: user-role.entity.ts, roles.guard.ts)*

03	JWT y claves criptográficas (AUTH/STEGO)	Falsificación de tokens, manipulación de claims o ataques de confusión de algoritmo (alg: none, HS256).	Verificación deficiente de la firma o almacenamiento inseguro de claves de firma.	A	A	Alto	Firma asimétrica RS256 (RSA 2048-bit). Clave privada resguardada solo en AUTH; STEGO valida exclusivamente con la clave pública forzando algoritmo, emisor (iss), audiencia (aud), expiración (exp) y sujeto (sub). *(Evidencia:* auth.middleware.js*,* jwtSecurity.test.js*)*
04	Autorización vigente (AUTH/STEGO)	Ejecución de operaciones con roles revocados pero token JWT aún vigente en tiempo.	Confianza estática en los roles codificados en el JWT sin verificar el estado actual.	A	A	Alto	Zero Trust sin caché: STEGO consulta en tiempo real a AUTH (POST /internal/authorization/check) en cada petición protegida. Si el rol se revoca en BD, se deniega inmediatamente (HTTP 403). *(Evidencia:* authClient.service.js*,* zeroTrustAuth.test.js*)*
05	Comunicación S2S AUTH–STEGO	Suplantación de STEGO ante el endpoint interno de autorización de AUTH.	Endpoints internos expuestos en red sin autenticación mutua entre servicios.	M	A	Alto	Autenticación entre servicios mediante validación obligatoria de la cabecera X-Service-Credential en AUTH y red Docker interna aislada (proyecto_network). *(Evidencia:* auth.controller.ts*,* docker-compose.yml*)*
06	Disponibilidad de autorización (S2S)	Bypass de seguridad o procesamiento no autorizado cuando AUTH cae o está inaccesible.	Configuración de fallo abierto (*fail-open*) ante errores de red o timeouts.	M	A	Alto	Fallo Seguro (*Fail-Secure / Fail-Close*): Denegación por defecto con HTTP 503 ante caída, timeout (5s) o respuesta no verificable de AUTH, cancelando el procesamiento y borrando temporales. *(Evidencia:* authClient.service.js*,* zeroTrustAuth.test.js*)*

07	Archivos e imágenes recibidas (STEGO)	Carga maliciosa (*web shells*, ejecutables políglotas, *extension spoofing*, MIME falso).	Confiar en la extensión del archivo o en el encabezado Content-Type enviado por el cliente.	A	A	Alto	Defensa en profundidad: Lista blanca (.png, .bmp), verificación de *Magic Bytes* reales con file-type e inspección determinista de buffer binario. Decodificación estructural con sharp y validador DIB/BMP. *(Evidencia:* imageValidation.service.js*,* imageSecurity.test.js*)*
08	Almacenamiento de archivos (STEGO)	Sobrescritura de archivos del sistema o salto de directorio (*Path Traversal*).	Usar el nombre original proporcionado por el cliente como ruta física de almacenamiento .	M	A	Alto	Generación de nombres internos aleatorios (crypto.randomUUID()), sanitización con path.basename comprobando confinamiento en directorio base y permisos 0o700. *(Evidencia:* fileStorage.service.js*,* fileStorage.service.test.js*)*
09	Gestión de temporales (STEGO)	Fuga de espacio en disco y acumulación de archivos huérfanos por peticiones fallidas.	Falta de limpieza cuando ocurre un error de validación o interrupción del análisis.	M	M	Medio	Middleware centralizado de errores que garantiza la eliminación (unlink) inmediata del archivo temporal ante cualquier rechazo HTTP (400, 401, 403, 413, 415, 422, 500, 503). *(Evidencia:* error.middleware.js*,* steganography.api.test.js*)*
10	Cuarentena de imágenes (STEGO)	Acceso público no autorizado o ejecución accidental de cargas sospechosas.	Exposición de carpetas de almacenamiento a través del servidor web.	B	A	Medio	Aislamiento físico en storage/quarantine: sin ruta ni endpoint que sirva la carpeta, nombres internos aleatorios (UUID), directorios con permisos 0700 y servicio ejecutado como usuario no privilegiado (USER node). *(Evidencia: app.js, fileStorage.service.js, Dockerfile)*

11	Recursos de cómputo y memoria (STEGO)	Denegación de servicio (DoS) mediante bombas de descompresión (*Pixel Flood / Zip Bomb*).	Alojamiento descontrolado de memoria según dimensiones falsificadas en la cabecera.	M	A	Alto	Límite de tamaño de archivo (5 MB) y dimensiones máximas (4096 × 4096 px). El lector BMP valida que los datos caben físicamente antes de reservar buffers de memoria. *(Evidencia:* imageValidation.service.js*,* pixelReader.test.js*)*
12	Resultados de análisis (STEGO)	Acceso no autorizado a análisis ajenos (*IDOR / Broken Object Level Authorization*).	Parámetros de consulta predecibles o falta de verificación de propiedad del recurso.	A	A	Alto	Verificación de autorización por recurso: AUTH decide el permiso (steganography.view_result) y STEGO comprueba que el análisis pertenezca al usuario autenticado (claim sub del JWT verificado). Solo el propietario puede consultarlo; el análisis de otro usuario se rechaza con HTTP 403 sin revelar datos. Pendiente en AUTH: reconocer la acción steganography.view_result. *(Evidencia: steganography.controller.js, analysisFlow.test.js)*
13	Persistencia de análisis (STEGO)	Inyección SQL y alteración de los registros de evidencia forense.	Concatenación de parámetros del cliente en consultas SQL de inserción o búsqueda.	M	A	Alto	Consultas SQL 100 % parametrizadas en PostgreSQL, identificadores UUID y restricciones CHECK en el DDL (status, action y formato del SHA-256). Los registros no son de solo inserción a nivel de base de datos (mejora prevista: un rol con permisos INSERT y SELECT). *(Evidencia: analysisRepository.js, 001_create_analysis_results.sql)*

14	Bitácoras y registros (STEGO)	Fuga de información confidencial en logs (*Log Injection / Data Leakage*).	Impresión en consola o archivo de JWTs completos, contraseñas, claves o trazas internas.	M	A	Alto	Logger estructurado en JSON con lista blanca estricta de campos permitidos (ALLOWED_FIELDS) en STEGO, que neutraliza la inyección de saltos de línea y nunca registra secretos ni tokens. *(Evidencia: audit.js, audit.test.js)*
15	Contenedores y SO (Infraestructura)	Compromiso del sistema operativo host y escalada de privilegios por escape de contenedor.	Ejecución de aplicaciones Node.js/NestJS como usuario superusuario (root).	B	A	Medio	Imágenes Docker basadas en Alpine Linux ejecutadas bajo usuario no privilegiado (USER node), manejo de señales con dumb-init y PostgreSQL con no-new-privileges: true. *(Evidencia:* Dockerfile*,* docker-compose.yml*)*
16	Detección esteganográfica (STEGO)	Falsos negativos (evasión del detector LSB) o falsos positivos que bloqueen imágenes legítimas.	Limitaciones del análisis estadístico ante bajas densidades de carga o ruidos en la imagen.	A	M	Alto	Algoritmo chi-cuadrado sobre pares de valores (progresivo) calibrado con 24 fotografías reales y 3 propias. Emisión de 4 estados (sin_indicios, sospechoso, no_concluyente, con_error) y declaración de limitaciones en cada respuesta (el texto plano y las cargas pequeñas pueden no detectarse). *(Evidencia: lsbAnalyzer.js, teoria-esteganografia.md, resultados.md)*

Referencias

Westfeld, A. y Pfitzmann, A. (1999). Attacks on Steganographic Systems. Information Hiding (IH 1999), LNCS 1768, 61–76. Springer.

Fridrich, J., Goljan, M. y Du, R. (2001). Detecting LSB steganography in color and gray-scale images. IEEE Multimedia, 8(4), 22–28.

Dumitrescu, S., Wu, X. y Wang, Z. (2003). Detection of LSB steganography via sample pair analysis. IEEE Transactions on Signal Processing, 51(7), 1995–2007.

Provos, N. y Honeyman, P. (2003). Hide and Seek: An Introduction to Steganography. IEEE Security & Privacy, 1(3), 32–44.

OWASP Foundation. (s. f.). File Upload Cheat Sheet. OWASP Cheat Sheet Series.